

Table of Contents

1. Incident Overview.....	2
2. Executive Summary.....	2
3. Threat Intelligence & Framework Mapping.....	3
4. Technical Timeline & Event Analysis.....	4
5. Scope & Impact Assessment.....	6
6. Remediation & Actionable Recommendations.....	7
7. Post-Incident Lessons Learned & Posture Hardening.....	8
Appendix: Raw Telemetry & Forensic Artifacts.....	9

INCIDENT RESPONSE & FORENSIC ANALYSIS REPORT

1. Incident Overview

This section provides a high-level administrative summary and core metadata for the identified security incident under investigation.

Fields	Values
Incident ID	INC-2026-001
Incident Title	Windows RDP Brute Force Attack Detected
Incident Severity	Critical
Impacted Asset	WIN-2UE57T0GMVM (192.168.100.20)
Detection Source	Wazuh SIEM
Date Detected	1 July 2026
Time Detected	03:17:18 UTC
Analyst	Ufuoma Unuawotota
Status	Under Investigation

2. Executive Summary

On July 1, 2026, an automated brute-force activity was detected targeting the default administrative account on an internal Windows Server. The Wazuh monitoring platform identified a high-volume influx of authentication failures immediately followed by a successful logon from an unauthorized source IP (192.168.100.10), indicating a confirmed compromise of the asset.

3. Threat Intelligence & Framework Mapping

The observed malicious activity has been evaluated against the **MITRE ATT&CK** framework, combining automated SIEM correlation rules with secondary analyst verification:

Phase 1: Pre-Compromise (The Authentication Failures)

SIEM-Generated Mapping: As recorded in the telemetry logs (*Rule ID: 60122*), the *out-of-the-box alerting mapped the event to:*

- **Tactics:** Initial Access, Defense Evasion, Persistence, Privilege Escalation
- **Techniques:** Valid Accounts (T1078), Account Access Removal(T1531)

Analyst Evaluation: While Wazuh's built-in rule flags this broadly as an issue with a "Valid Account", my analysis of the attack behavior shows a massive, rapid flood of 14+ login failures. Therefore, this activity is behaviorally a **Credential Access** tactic, specifically using the technique **Brute Force: Password Brute Forcing**(T1110.001)

- **Tactic:** Credential Access (TA0006)
- **Technique:** Brute Force (T1110)
- **Sub-Technique:** Password guessing (T1110.001)

Phase 2: Post-Compromise (The Successful Logon)

As verified in the Wazuh alert payload (*Rule ID: 92657*), once the adversary successfully authenticated (Windows Event ID 4624), the platform correctly escalated the mapping to reflect an active foothold and lateral capabilities:

- **Tactics:** Initial Access, Lateral Movement, Privilege Escalation, Defense Evasion, Persistence
- **Techniques:** Remote Desktop Protocol (T1021.001), Domain Accounts (T1078.002), Pass the Hash (T1550.002)

Threat Actor Profile & Attribution

- **Actor Classification:** Opportunistic Threat Actor / Automated Botnet.
- **Origin IP:** 192.168.100.10 (Internal Private Range / Simulated External Adversary) .
- **Behavioral Profile:** The threat actor relies on noisy, automated scanning and brute-force utilities rather than sophisticated, low-and-slow evasion techniques. The actor targeted a well-known, default administrative identifier (Administrator) via a publicly exposed service port (RDP). This indicates an opportunistic attack profile aiming for quick, high-privilege system compromise rather than targeted espionage.

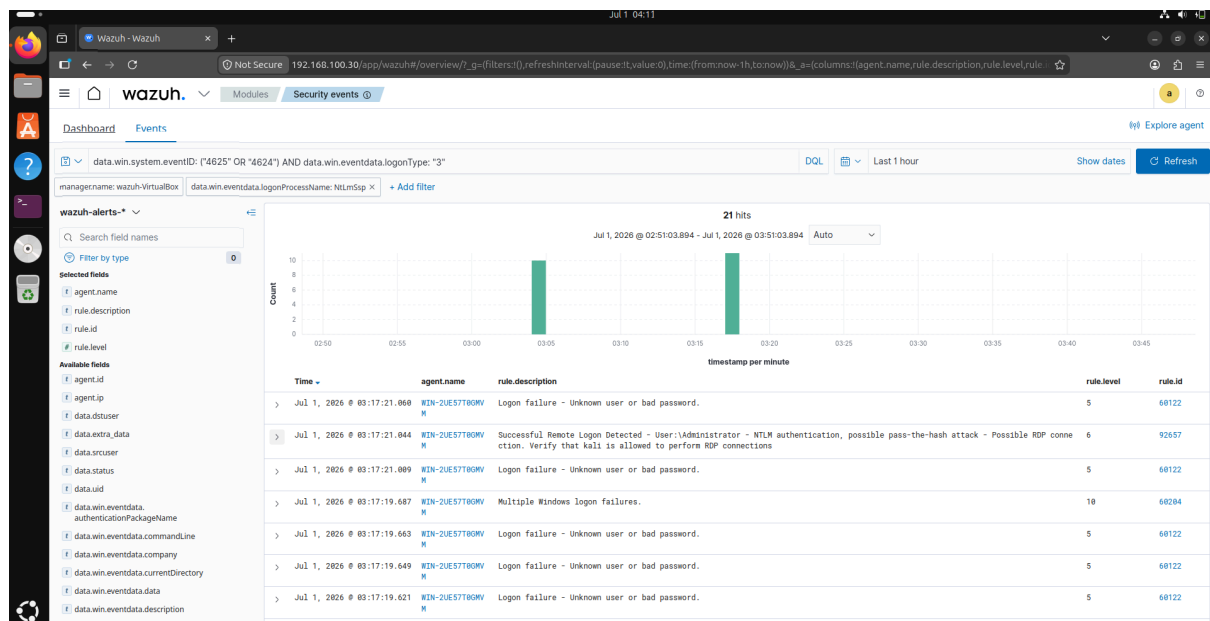
4. Technical Timeline & Event Analysis

A. Chronological Narrative

On **July 1, 2026**, a high-volume authentication attack targeted the local administrative account of the Windows host. The incident progressed across two distinct phases:

- **03:17:18 UTC - Attack Initiation:** The adversary initiated a rapid succession of automated password guesses from the source IP **192.168.100.10**. This behavior generated 14+ immediate **Event ID 4625 (Logon Failure)** events within the SIEM platform.

Figure 4.1: Wazuh discovery stream illustrating the high-density alert volume during the brute-force attempt



- **03:17:21 UTC - Asset Compromise:** Within three seconds of the initial burst, the automated tool successfully identified the correct credential payload. A single Event ID 4624 (Logon Success) was recorded from the identical source IP **192.168.100.10**, confirming a successful system compromise.

Figure 4.2: Telemetry detail confirming the successful Remote Desktop authentication event.

Modules

Security events (3)

data.command

data.dstuser

data.extra_data

data.pwd

data.srcuser

data.status

data.tty

data.uid

data.win.eventdata.authenticationPackageName

data.win.eventdata.elevatedToken

data.win.eventdata.failureReason

data.win.eventdata.impersonationLevel

data.win.eventdata.ipAddress

data.win.eventdata.iPort

data.win.eventdata.keyLength

data.win.eventdata.lmPackageName

data.win.eventdata.logonGuid

data.win.eventdata.logonProcessName

data.win.eventdata.logonType

data.win.eventdata.processId

data.win.eventdata.status

data.win.eventdata.subjectLogonId

data.win.eventdata.subjectUserId

data.win.eventdata.subStatus

data.win.eventdata.targetDomainName

data.win.eventdata.targetLinkedLogonId

data.win.eventdata.targetLogonId

data.win.eventdata.targetUserName

Jul 1, 2026 @ 03:17:21.044

WIN-2UE5770GWM

Successful Remote Logon Detected - User:Administrator - NTLM authentication, possible pass-the-hash attack

Possible RDP connection. Verify that kall is allowed to perform RDP connections

6

92657

Expanded document

Table

JSON

data._index	wazuh-alerts-4.x-2026.07.01
data.agent.id	001
data.agent.ip	192.168.100.20
data.agent.name	WIN-2UE5770GWM
data.win.eventdata.authenticationPackageName	NTLM
data.win.eventdata.elevatedToken	\%1842
data.win.eventdata.impersonationLevel	\%1833
data.win.eventdata.ipAddress	192.168.100.10
data.win.eventdata.iPort	0
data.win.eventdata.keyLength	128
data.win.eventdata.lmPackageName	NTLM V2
data.win.eventdata.logonGuid	{00000000-0000-0000-0000-000000000000}
data.win.eventdata.logonProcessName	NtLmSsp
data.win.eventdata.logonType	3
data.win.eventdata.processId	0x0
data.win.eventdata.subjectLogonId	0x0
data.win.eventdata.subjectUserId	S-1-0-0

Artifact / Indicator	Logged Value	Supporting Wazuh Field	Context / Analysis
Attacker Source IP	192.168.100.10	data.win.eventdata.ipAddress	Identifies the unauthorized device launching the attack.
Targeted Username	Administrator	data.win.eventdata.targetUsername	Confirms the adversary targeted a high-privilege account.
Logon Category	3 (Network Logon)	data.win.eventdata.logonType	Indicates that an automated tool bypassed standard interactive desktop UI.
Authentication Failures	4625	data.win.system.eventID	Indicates a rapid volume of credential guessing attempts
Authentication Failures	4624	data.win.system.eventID	Identifies the exact timestamp the perimeter was breached
Target Hostname	WIN-2UE57T0GMVM	data.win.system.computer	Confirms the internal machine that was compromised.
Workstation Name	Kali	data.win.eventdata.workstationName	Identifies the hostname of the machine initiating the connection.

Logon Process Name	NtLmSsp	data.win.eventdata.logonProcessName	Specifies the trusted subsystem that submitted the logon credentials.
Process ID	600	data.win.system.processID	The internal kernel Process ID (PID) responsible for handling the authentication log generation.
Authentication Package	NTLM	data.win.eventdata.authenticationPackageName	Proves the exact protocol used to validate the password guesses.

Figure 4.3: Wazuh event data payload illustrating the system-level authentication artifacts captured during successful breach verification.

- data.win.eventdata.logonType - data.win.eventdata.processId - data.win.eventdata.status - data.win.eventdata.subjectLogonId - data.win.eventdata.subjectUserSid - data.win.eventdata.subStatus - data.win.eventdata.targetDomainName - data.win.eventdata.targetLinkedLogonId - data.win.eventdata.targetLogonId - data.win.eventdata.targetUserName - data.win.eventdata.targetUserSid - data.win.eventdata.virtualAccount - data.win.eventdata.workstationName - data.win.system.channel - data.win.system.computer - data.win.system.eventID - data.win.system.eventRecordID - data.win.system.keywords - data.win.system.level - data.win.system.message - data.win.system.opcode - data.win.system.processID - data.win.system.providerGuid - data.win.system.providerName - data.win.system.severityValue - data.win.system.systemTime - data.win.system.task - data.win.system.threadID	- data.win.eventdata.imPackageName - data.win.eventdata.logonId - data.win.eventdata.logonProcessName - data.win.eventdata.logonType - data.win.eventdata.processId - data.win.eventdata.subjectLogonId - data.win.eventdata.subjectUserSid - data.win.eventdata.targetDomainName - data.win.eventdata.targetLinkedLogonId - data.win.eventdata.targetLogonId - data.win.eventdata.targetUserName - data.win.eventdata.targetUserSid - data.win.eventdata.virtualAccount - data.win.eventdata.workstationName - data.win.system.channel - data.win.system.computer - data.win.system.eventID - data.win.system.eventRecordID - data.win.system.keywords - data.win.system.level
	- NTLM V2 {00000000-0000-0000-0000-000000000000} - NtLmSsp 5 0x0 0x0 - S-1-0-0 - WIN-2UE57T0GMVM 0x0 0x37c6474 - Administrator - S-1-5-21-2693679614-1994788561-2687465358-500 %\1843 - kal1 - Security - WIN-2UE57T0GMVM 4624 14251 0x8820000000000000 0

5. Scope & Impact Assessment

A. Asset & Scope Identification

A post-incident boundary analysis was conducted to determine the exact blast radius of the compromise and identify the affected system components:

- Target System Hostname: **WIN-2UE57T0GMVM**
- Compromised Identity: Local **Administrator** account
- **Blast Radius:** High. Because a local administrator account was compromised, the adversary has obtained unrestricted, root-level privileges over the local operating system.

B. Business & Operational Impact

The successful compromise of a high-privilege administrative account introduces critical risks to the security posture of the affected asset. The potential impact is categorized using the CIA Triad framework below:

- **Confidentiality (High Risk):** The attacker has the access required to view, modify, or exfiltrate sensitive files, user data, and system configurations stored on the host.
- **Integrity (High Risk):** With administrator privileges, the attacker can install malware, turn off antivirus tools, alter system logs to hide their tracks, or deploy ransomware to encrypt the system.
- **Availability (High Risk):** The adversary can disrupt operations entirely by locking out legitimate users, changing credentials, or shutting down critical system services.

6. Remediation & Actionable Recommendations

A. Immediate Incident Response Actions (Containment)

- **Rotate Administrative Credentials:** Immediately change the password for the local administrator account to a complex, randomly generated password (minimum 15+ characters).
- **Terminate Active Sessions:** Forcefully log off all active remote desktop sessions on the host **WIN-2UE57T0GMVM** to evict any live adversarial connections.
- **Isolate the Asset (If Required):** Network-isolate the host temporarily if further lateral movement or malware installation is suspected.

B. Long-Term Hardening Recommendations (Prevention)

To permanently reduce the attack surface and mitigate future brute-force attempts, implement the following security controls:

- **Enforce Account Lockout Policies:** Configure Windows Group Policy to lock accounts temporarily after a set number of failed attempts (e.g, lock the account for 30 minutes after 5 failed logins). This completely neutralizes high-velocity automated brute-forcing tools.
- **Restrict or Disable Direct Public RDP Access:** Ensure that RDP (Port 3389) is not directly exposed to untrusted networks. Require users to connect via a secure Virtual Private Network (VPN) or an architecture like a Just-In-Time (JIT) access gateway.

- **Implement Network Level Authentication (NLA):** Enforce NLA for Remote Desktop Services to force authentication *before* a full RDP session handshake is established, reducing system resource drain during denial-of-service style password attacks.
- **Deploy Multi-Factor Authentication (MFA):** Enforce MFA for all administrative and remote access logons to ensure that even if a password is successfully guessed, the attacker cannot achieve entry without the secondary factor.

7. Post-Incident Lessons Learned & Posture Hardening

A. Defensive Capability Assessment

An evaluation of the security infrastructure during the incident revealed key insights regarding the current visibility and response timeline:

- **Detection Success:** The Wazuh SIEM successfully ingested and alerted on both the high-velocity authentication failures (**Rule ID: 60122**) and the subsequent successful breach (**Rule ID: 92657**). The telemetry pipeline remained intact throughout the campaign.
- **Response Gap:** Although the SIEM generated accurate telemetry in real time, the lack of an automated active response mechanism allowed the threat actor to iterate through 14+ credential combinations in a matter of seconds until a match was found. Relying solely on human monitoring for high-velocity brute-force attacks introduces an unacceptable window of exposure.

B. Strategic Action Plan

To mature the organization's security posture beyond basic alerting, the following architectural improvements should be prioritized:

- **Deploy Wazuh Active Response (Automated Containment):** Configure the Wazuh manager to trigger an automated script upon detecting a high-density brute-force signature (e.g., more than 5 failed connection attempts within 10 seconds). The active response profile will automatically drop the traffic from the offending source IP at the host firewall level for 60 minutes, neutralizing the utility before a breach can occur.
- **Transition to Centralized Log Monitoring (Sysmon Integration):** While standard Windows Security Logs captured the logon IDs, integrating advanced **Microsoft Sysmon** telemetry alongside the Wazuh agent will grant deeper visibility. This ensures that if an account is compromised via RDP in the future, any immediate post-exploitation behavior (like spawning **cmd.exe**

or executing PowerShell scripts) is instantly mapped to a specific process tree.

- **Continuous Security Awareness & Password Hygiene:** Establish routine credential-auditing procedures to identify and eliminate easily guessable default account profiles across all internal assets.

Appendix: Raw Telemetry & Forensic Artifacts

A. Core Telemetry Definitions

This appendix details the technical mappings and log schemas applied during the lab simulation to translate raw Windows event logs into actionable Indicators of Compromise (IoCs).

- **Event ID 4625 (Logon Failure):** Generated when an authentication request fails. Key monitoring fields include **TargetUserName** (the account targeted) and **IPAddress** (the network origin of the attack vector).
- **Event ID 4624 (Logon Success):** Generated when an authentication request successfully passes verification. **The LogonType** field is audited to determine the mechanism of entry (e.g., Type 3 for Network or Type 10 for Remote Desktop Protocol).
- **Wazuh Rule Engine ID 60122:** A built-in rule triggered by multiple failed logon events, indicating automated or rapid-succession credential testing.
- **Wazuh Rule Engine ID 92657:** A built-in security alert denoting a successful remote desktop authentication event, establishing system compromise in this event flow.

B. Evidence References

All supporting visual evidence referenced throughout this report is cataloged sequentially below

- **Figure 4.1:** Wazuh discovery stream dashboard illustrating the high-density alert volume during the automated brute-force attempt.
- **Figure 4.2:** Telemetry detail confirming the successful Remote Desktop Protocol (RDP) authentication event payload.
- **Figure 4.3:** The core structured configuration mapping the ingested Wazuh fields (data.win.eventdata.ipAddress, data.win.eventdata.targetUserName) to their analytical real-world significance.